

中山大学

《软件工程》期末大作业

逸仙活动云 软件配置与运维文档

项目名称： 校园活动信息平台（逸仙活动云）

组长学号： _____

组长姓名： _____

课程教师： _____

提交日期： 2026 年 _____ 月 _____ 日

版本： 1.0 文档状态： 提交版

目录

1	目标与配置项范围	1
2	版本控制与基线策略	1
3	环境与密钥管理	2
4	持续集成与制品管理	2
5	部署流程	2
6	监控、日志、备份和故障处置	3
7	变更、回滚与演化	3
8	现有配置项核对与生产约束	4
9	发布前检查清单	4
10	运维责任边界	4

文档范围：本报告依据前端仓库（Vue 3）与后端仓库（Flask）截至 2026-07-18 的代码、配置及测试资产编写。**术语说明：**“已实现”指代码库已有对应实现；“计划”指建议在交付/运维阶段落实，二者不混同。

1 目标与配置项范围

本计划确保每个交付版本可识别、可重建、可部署、可监控和可恢复。配置管理对象包括：前端源码与锁文件、后端源码与依赖清单、接口契约、测试和文档、环境变量样例、Dockerfile/Compose/Gunicorn 配置、数据库 schema/初始化数据、CI 工作流及发布制品。不纳入仓库的配置项包括 .env、JWT/邮件/AI 密钥、真实数据库、用户附件和生产日志。

2 版本控制与基线策略

前端、后端为相邻独立仓库，发布时以兼容版本对组成系统基线，记录：前端 commit/tag、后端 commit/tag、接口契约版本、数据库 schema 版本、镜像摘要和环境模板版本。主分支保持可构建；功能在短生命周期分支完成，经评审与 CI 通过后合并。建议 tag 使用 vMAJOR.MINOR.PATCH，例如 v1.0.0；破坏性接口或数据库变更递增 MAJOR，兼容功能递增 MINOR，缺陷修复递增 PATCH。

提交应小而聚焦，消息包含模块与目的；合并请求关联需求/缺陷编号、验证证据和文档更新。发生紧急生产修复时，从受影响 tag 建立 hotfix，修复后同时合回主分支和发布分支。禁止强制覆盖共享历史、提交密钥或将构建产物/本地数据库作为源代码基线。

3 环境与密钥管理

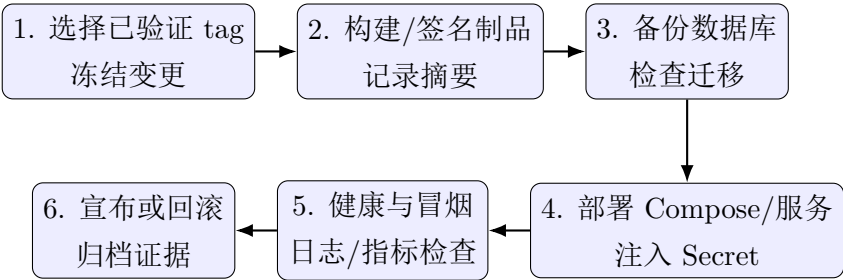
环境	配置原则	数据/依赖
本地开发	前端复制 <code>.env.example</code> 为 <code>.env.local</code> ；后端复制为 <code>.env</code> ；默认 API 代理指向本地。	可用 Mock 或 SQLite；不使用生产密钥/数据。
测试/CI	变量由 CI Secret 或临时环境注入，测试配置使用内存 SQLite、禁用真实邮件/LLM/Redis。	可重复、隔离、可清理。
预发布	与生产拓扑尽量一致，使用独立数据库、Redis、域名和最小权限账号。	脱敏样本数据，执行迁移/回滚演练。
生产	密钥存入受控 Secret 管理服务，容器只读环境注入；HTTPS、备份和监控必须启用。	PostgreSQL、Redis、Worker/Beat、反向代理。

需要重点配置的变量包括 `DATABASE_URL`、`REDIS_URL`、`JWT_SECRET_KEY`、`CORS`/前端 API 地址、邮件服务和 AI/搜索服务凭据。密钥不得记录在报告、Issue、日志或截图中；发现泄露后立即撤销、轮换、审计访问并重建制品。`.env.example` 只保留变量名与无敏感示例。

4 持续集成与制品管理

前端现有 GitHub Actions 在 push/PR 上执行：检出代码、Node 22、`npm ci`、安装 Chromium、`npm run build`、`npm run test:unit`、`npm run test:e2e`。后端当前具备 `pytest` 测试资产和 `Dockerfile`；建议增加同等的 CI 工作流，执行依赖安装、`pytest`、静态检查、依赖漏洞扫描与镜像构建。发布制品应包含前端静态构建包、后端不可变镜像、SBOM/依赖清单、测试报告和 `release notes`，并以 tag 与 commit SHA 双重标识。

5 部署流程



当前后端提供 Dockerfile、docker-compose.yml 与 Gunicorn 配置，Compose 定义 API、PostgreSQL、Redis、Worker、Beat 和数据卷；API 仅绑定 127.0.0.1:5000，生产应由反向代理暴露 HTTPS。部署前检查环境文件、镜像版本和卷挂载；运行 docker compose up -d --build 后访问 GET /api/health，再验证登录、活动查询和审核等最小业务流。首次启动自动建表只适于开发/演示，生产必须先执行受控迁移。

6 监控、日志、备份和故障处置

领域	运行措施	告警/处置
可用性	反向代理探针 + /api/health；记录 API 5xx、延迟、容器重启数。	连续探针失败或错误率突增：停止发布、检查 API/数据库/Redis 日志，必要时回滚。
任务队列	记录任务成功/失败、重试、等待时间与抓取统计。	积压或失败激增：暂停问题数据源、检查 Worker/Redis 和外部依赖。
审计/安全	请求标识、脱敏搜索日志、审核与管理动作审计；限制日志保留和访问。	异常登录、越权或密钥泄露：撤销凭据、保全日志、评估数据影响并修复。
备份恢复	PostgreSQL 每日全量、适当的日志/WAL 增量；备份加密、异地/独立存储，定期恢复演练。	恢复目标需由团队确定；恢复时先隔离故障环境，再恢复最近一致备份并验证核心数据。

建议指标包括 API 请求量、P50/P95/P99 延迟、4xx/5xx、数据库连接/慢查询、Redis 内存、队列深度、磁盘/卷使用率和备份最近成功时间。日志不得输出密码、JWT、完整邮箱验证码、身份证号或完整搜索词。保留策略、备份 RPO/RTO、告警接收人和演练日期应在实际部署前由团队填入运维值班表。

7 变更、回滚与演化

配置变更与代码变更同样需要评审和记录。数据库变更采用“先向后兼容扩展、应用双读写/回填、切换、再删除”的迁移策略；每次迁移必须有备份和回滚方案。发布后若健康检查、核心冒烟或错误指标不达标，应停止流量切换，恢复上一镜像和兼容 schema，保留日志与版本信息，创建缺陷并复盘。下一步优先落地 schema migration、后端 CI、镜像扫描、TLS/反向代理、集中指标与备份恢复演练，逐步将课程项目的可部署能力提升为可长期运维能力。

8 现有配置项核对与生产约束

配置项	当前样例/位置	生产约束
VITE_API_BASE_URL	前端 .env.example, 默认 /api。	同源代理保持 /api；跨域部署需显式 CORS 与 HTTPS。
DATABASE_URL / REDIS_URL	后端 .env.example。	使用独立最小权限账号、TLS/网络隔离和备份；不得复用开发 SQLite。
JWT_SECRET_KEY	样例含占位默认值。	部署时由 Secret 注入高熵随机值；泄露立即轮换，绝不提交真实值。
默认管理员凭据	样例中有开发账号密码。	仅用于本地演示；生产首次部署必须强制替换/禁用默认账户。
LLM/嵌入/MCP 凭据	后端样例提供可选变量。	仅在启用相应服务时注入，限制权限/配额；日志和异常中不得回显。
抓取限制	间隔、页数、超时、内网阻断变量。	按目标站点和合规要求调整，保留审计、失败重试和人工暂停开关。

9 发布前检查清单

1. 选择已通过质量门禁的前后端 commit/tag，并冻结接口和数据库迁移版本；
2. 确认无真实密钥、.env、本地数据库或测试附件进入制品；
3. 在预发布恢复备份、执行迁移及前端/后端冒烟，记录输出和镜像摘要；
4. 复核反向代理 TLS、CORS、请求体限制、健康检查、日志脱敏与告警接收人；
5. 部署后验证健康接口、登录、活动浏览、发布审核和审计查询；失败即按已验证版本回滚；
6. 归档 release notes、配置变更、已知风险、监控链接和恢复点。

10 运维责任边界

课程项目当前代码提供 Docker/Compose 和健康检查入口，但没有证据表明已配置生产 TLS、集中监控、自动备份、分支保护或灾备演练。因此这些项目均列为上线前必做项而非“已完成运维”。每次运行事故由值班人员先止损和保全日志，再由开发、测试、运维共同完成根因分析、修复、回归验证和预防行动跟踪。